

NIST

National Institute of Standards
and Technology

U.S. Department of Commerce

Version 2.0 · Feb 2024

CYBERSECURITY STUDY NOTES

Cybersecurity Framework

2.0

GOVERN

IDENTIFY

PROTECT

DETECT

RESPOND

RECOVER

“

The CSF helps organisations of all sizes manage and reduce cybersecurity risk through a common language and flexible, risk-based, outcomes-driven guidance.

— National Institute of Standards and Technology, 2024

WHAT'S INSIDE

Overview & History

Six Core Functions

GOVERN (New in 2.0)

IDENTIFY & PROTECT

DETECT / RESPOND / RECOVER

CSF Tiers 1–4

Profiles & Implementation

Alignment & Takeaways

YG

Yadav Ghorasainee

linkedin.com/in/yadav-ghorasainee

yadavgybernet.github.io/sec/

Information Security Professional · ISM · GDPR · CSF 2.0 · Essential Eight

What is NIST CSF 2.0?

Overview · History · Key Facts · Document Structure · What's New

ABOUT THE FRAMEWORK

Published by NIST	Who Uses CSF 2.0?	Three Core Components
- National Institute of Standards & Technology - U.S. Department of Commerce - Released: 26 February 2024 - Supersedes CSF 1.1 (April 2018) - Free download: nist.gov/cyberframework - Available in multiple languages globally - Includes Quick Start Guides (QSGs) for all sizes	- ALL organisations — any size, any sector globally - Previously: primarily critical infrastructure only - Now: explicitly universal scope worldwide - Government & private sector equally applicable - SMEs to large enterprises and sovereign agencies - Adopted globally as de-facto standard - Aligned with ISO 27001, ISM, NIST SP 800-53	- CORE: 6 Functions → 22 Categories → 106 Subcategories + Examples - Outcomes-based, not prescriptive - TIERS: 4 maturity practice levels - Partial (1) through Adaptive (4) - PROFILES: Current vs Target state - Gap analysis drives action planning

WHAT'S NEW IN CSF 2.0 vs CSF 1.1

1. GOVERN Function Added (New) - Brand-new 6th function added in CSF 2.0 - Elevates governance as the cross-cutting foundation - Covers risk strategy, roles, policy and oversight - Supply chain risk management (GV.SC) included - Informs and directs all other five functions	2. Universal Applicability - Designed for ALL organisations — not just critical infrastructure - Explicitly includes SMEs with tailored Quick Start Guides - Sector-agnostic outcomes and language used throughout - Applicable to non-profits, healthcare, finance, education - Applicable internationally, not only within the USA
3. Supply Chain Risk Management Focus - Dedicated GV.SC category for supply chain risk practices - Third-party and vendor risk explicitly and formally addressed - Security requirements in supplier contracts now mandated - Continuous monitoring of third-party posture required - Risk criteria for supplier selection formally defined	4. New Implementation Resources - Implementation Examples added to every subcategory - Community Profiles introduced for sector-wide adoption - Improved integration with ISO 27001 and SP 800-53 - Searchable online CSF reference tool at nist.gov - Informative References mapping to 50+ standards

THE THREE CSF COMPONENTS

CORE	TIERS	PROFILES
- Organises desired cybersecurity outcomes 6 Functions → 22 Categories → 106 Subcategories - Each subcategory has implementation examples - Not a checklist — outcomes-based guidance - Technology and sector agnostic throughout	- Describes degree of CSF practice maturity - Tier 1: Partial — informal and reactive - Tier 2: Risk Informed — approved, not mandated - Tier 3: Repeatable — formal consistent policy - Tier 4: Adaptive — culture-embedded, evolving - NOT compliance levels — contextual	- Current Profile: outcomes being achieved now - Target Profile: desired future-state outcomes - Gap = Target – Current = priority actions - Org-specific to risk context and objectives - Drives cybersecurity roadmaps and budgeting - Community Profiles available for each sector - Updated at least annually or on major change

KEY FACTS AT A GLANCE

Attribute	Detail
Published by	National Institute of Standards & Technology (NIST), U.S. Department of Commerce
Latest version	CSF 2.0 — Released 26 February 2024 Supersedes CSF 1.1 (April 2018)
Scope	All organisations regardless of sector, size, maturity, or geographic location
Core structure	6 Functions · 22 Categories · 106 Subcategories · Implementation Examples
Download	Free at nist.gov/cyberframework — includes Quick Start Guides for all org sizes

REAL-WORLD APPLICATION:
Scenario: A medium-sized Australian financial firm with no formal security programme adopts CSF 2.0.
Step 1 — GOVERN: Leadership defines risk appetite and appoints the CISO as cybersecurity risk owner.
Step 2 — IDENTIFY: IT team inventories 280 assets, discovers 3 unpatched internet-facing systems.
Step 3 — PROTECT: MFA enforced for all remote access; AES-256 encryption applied to sensitive data.
Step 4 — Current Profile to Target Profile gap analysis produces a prioritised 90-day action roadmap.
Step 5 — DETECT: SIEM deployed; automated alerts configured for anomalous login events and data exfil.

The Six Core Functions

GOVERN · IDENTIFY · PROTECT · DETECT · RESPOND · RECOVER

The CSF Core organises cybersecurity outcomes into six Functions — each representing a distinct domain of risk management that operates simultaneously and

FUNCTION OVERVIEW CARDS

GVGOVERN

The cross-cutting foundation. Establishes cybersecurity risk strategy, risk tolerance, roles, policy and governance. Informs and directs all five other functions.

- GV.OC — Organizational Context
- GV.RM — Risk Management Strategy
- GV.RR — Roles & Responsibilities
- GV.PO — Policy
- GV.OV — Oversight
- GV.SC — Supply Chain Risk

IDIDENTIFY

Understand the current cybersecurity risk picture across assets, data, capabilities, people and technology. The risk knowledge that drives all other functions.

- ID.AM — Asset Management
- ID.RA — Risk Assessment
- ID.IM — Improvement

PRPROTECT

Implement safeguards to manage identified cybersecurity risks and limit the likelihood and impact of adverse cybersecurity events across all systems.

- PR.AA — Identity & Access
- PR.AT — Awareness & Training
- PR.DS — Data Security
- PR.PS — Platform Security
- PR.IR — Infrastructure Resilience

DEDETECT

Find and analyse possible cybersecurity attacks, compromises and anomalous activity promptly to minimise dwell time and reduce incident impact.

- DE.CM — Continuous Monitoring
- DE.AE — Adverse Event Analysis

RSRESPOND

Take timely action regarding a detected cybersecurity incident to contain lateral spread and limit the overall impact to the organisation.

- RS.MA — Incident Management
- RS.AN — Incident Analysis
- RS.CO — Incident Communication
- RS.MI — Mitigation
- RS.IM — Improvements

RCRECOVER

Restore assets, operations and services affected by a cybersecurity incident to normal operation in a timely and verified manner.

- RC.RP — Incident Recovery Plan
- RC.CO — Recovery Communication
- RC.IM — Recovery Improvements

FUNCTION QUICK REFERENCE TABLE

Code	Function	Primary Role	Categories
GV	GOVERN	Cybersecurity strategy, risk tolerance & governance	6: Context, Risk Strategy, Roles, Policy, Oversight, Supply Chain
ID	IDENTIFY	Understand current cybersecurity risk landscape	3: Asset Management, Risk Assessment, Improvement
PR	PROTECT	Implement safeguards to manage and limit cyber risk	5: Identity/Access, Training, Data, Platform, Resilience
DE	DETECT	Find and analyse attacks, compromises and anomalies	2: Continuous Monitoring, Adverse Event Analysis
RS	RESPOND	Act to contain a detected cybersecurity incident	5: Management, Analysis, Communication, Mitigation, Improvement
RC	RECOVER	Restore operations after a cybersecurity incident	3: Recovery Plan, Communication, Improvement

KEY PRINCIPLES:

The six functions do NOT represent a linear sequence — they operate simultaneously and continuously. GOVERN is the foundation layer: risk strategy, roles and policies defined here flow into all other functions. Core cycle: Know your risk (IDENTIFY) → Reduce it (PROTECT) → Find threats (DETECT) → Act (RESPOND) → Restore (RECOVER). Any cybersecurity programme can be mapped to these six functions regardless of its current maturity level. GOVERN was added in CSF 2.0 because organisations lacking governance consistently failed at the other five functions. Total categories: 6 + 3 + 5 + 2 + 5 + 3 = 24 categories covering 106 subcategories across the entire CSF Core. Each subcategory includes multiple Implementation Examples that organisations can use as practical starting points. CSF 2.0 is fully cross-referenced to ISO 27001:2022, NIST SP 800-53, CIS Controls and 50+ other frameworks.

★ NEW IN CSF 2.0 — GOVERN is the cross-cutting foundation informing every other function ★

GV

GOVERN

Establishes the organisation's cybersecurity risk strategy, risk appetite, expectations, policies and governance mechanisms. Answers: Who is responsible? What risks will we accept? What are our policies? Every other function draws its direction and boundaries from GOVERN.

SIX GOVERN CATEGORIES — DETAILED BREAKDOWN

GV.OC — Organizational Context

- Mission, objectives and stakeholder expectations identified
- Legal, regulatory and contractual requirements understood
- Critical infrastructure dependencies documented and mapped
- Risk environment and current threat landscape assessed
- Internal and external context communicated to all stakeholders

GV.RM — Risk Management Strategy

- Risk appetite and risk tolerance defined by senior leadership
- Risk management methodology formally approved and documented
- Risk strategy reviewed and communicated across the organisation
- Strategic cybersecurity objectives established and tracked annually
- Residual risk acceptance process defined and followed consistently

GV.RR — Roles, Responsibilities & Authorities

- Cybersecurity roles, responsibilities and authorities defined
- Accountability assigned to named senior leaders and owners
- Roles communicated and coordinated across all business units
- Third-party and supplier roles and obligations documented
- Succession plan for critical cybersecurity roles maintained

GV.PO — Policy

- Cybersecurity policies established and aligned to laws and strategy
- Policies reviewed, approved and updated on a defined cycle
- Policies communicated to all relevant personnel and third parties
- Exceptions, waivers and deviations formally approved and tracked
- Policy compliance monitored and enforcement mechanisms defined

GV.OV — Oversight

- Cybersecurity risk results reported to and reviewed by leadership
- Performance metrics defined, tracked and reported against targets
- Outcomes from assessments used to update risk strategy directly
- Independent reviews conducted to verify control effectiveness
- Board-level cybersecurity risk briefings conducted regularly

GV.SC — Supply Chain Risk Management

- Cybersecurity supply chain risk management plan formally established
- Security requirements embedded in all supplier contracts and SLAs
- Criteria for vetting and selecting suppliers formally documented
- Third-party security posture monitored and reviewed continuously
- Incident response obligations defined and agreed for all key suppliers

GOVERN — IMPLEMENTATION GUIDANCE

Governance Area	What Organisations Must Establish
Risk Appetite	Document acceptable cyber risk level — formally approved by board or senior exec and reviewed annually
Roles & Ownership	Assign named owners for cybersecurity decisions, accountability and execution; publish an RACI matrix
Policy Framework	Policies aligned to CSF, laws and risk tolerance — reviewed, communicated to all staff, and enforced
Supplier Management	Cyber clauses in all vendor contracts; monitor third-party posture quarterly; SLA breach obligations defined
Board Oversight	Regular reporting to board on cyber posture using consistent KRIs; findings update risk strategy directly

GOVERN IN PRACTICE:

Scenario: A large Australian government department implements GOVERN as its first CSF 2.0 activity.

GV.OC: CISO maps all applicable legal obligations including PSPF, ISM, Privacy Act and SOCI Act obligations.

GV.RM: A risk appetite statement is presented to and formally approved by the Secretary each financial year.

GV.RR: Named cybersecurity owners appointed in every division; a full RACI matrix published on the staff intranet.

GV.PO: Fourteen cybersecurity policies reviewed, updated and distributed; an annual policy attestation introduced.

GV.SC: All ICT vendor contracts revised to include mandatory security clauses and breach notification within 4 hours.

GV.OV: CISO presents a quarterly cybersecurity risk dashboard to the Executive Board using 10 key risk metrics.

GV.OV: Independent security assessment commissioned annually; findings formally tabled at Audit Committee meeting.

Outcome: Organisation moves from Tier 1 (no governance) to Tier 3 (Repeatable governance) within 12 months.

Key lesson: Without GOVERN in place, all other CSF functions lack direction — governance must come first.

ID — IDENTIFY

Asset Management · Risk Assessment · Improvement

ID

IDENTIFY

Understand the organisation's current cybersecurity risk across assets, data, people, capabilities and technology. You cannot protect what you don't know exists. IDENTIFY creates the complete risk picture that drives the direction of every other function.

THREE IDENTIFY CATEGORIES — DETAILED BREAKDOWN

ID.AM Asset Management

- Hardware assets inventoried and maintained
- Software assets catalogued with version details
- Data assets classified and mapped to owners
- External information systems fully identified
- Network connections and topology documented
- Assets prioritised by business criticality score
- Maintenance and repair activities logged
- Unauthorised assets detected and removed promptly
- Asset register reviewed and validated quarterly

ID.RA Risk Assessment

- Asset vulnerabilities identified and documented
- Threat intelligence gathered and analysed regularly
- Threat events formally documented and reviewed
- Business impact of each threat fully determined
- Likelihood of threat exploitation formally assessed
- Risk response priorities formally set and approved
- Residual risk accepted or escalated to leadership
- Cyber risk results communicated to exec leadership
- Risk register maintained and reviewed monthly

ID.IM Improvement

- Improvements identified from all security assessments
- Improvements identified from penetration tests
- Improvements from security incidents formally logged
- Improvements from exercises and tabletop activities
- Improvement plan prioritised against business risk
- Effectiveness of improvements evaluated over time
- Improvement feedback loop to GOVERN (GV.OV)
- Continuous improvement culture embedded in teams
- Improvement metrics tracked and reported monthly

ASSET CLASSIFICATION WORKFLOW

1

Discover

Enumerate all hardware, software, data, cloud and user accounts

2

Classify

Group by type: data, system, network, facility, people, supplier

3

Prioritise

Rank by criticality, sensitivity and regulatory obligation

4

Document

Record in a maintained, versioned CMDB or asset register

5

Review

Update continuously — full validation quarterly at minimum

IDENTIFY — KEY QUESTIONS AND EXPECTED OUTCOMES

Category	Key Question + Expected Outcome
ID.AM — Asset Management	What assets exist, where are they, and which are critical to mission? — Maintained, current CMDB
ID.RA — Risk Assessment	What threats face our assets and what is the likely business impact if exploited? — Current risk register
ID.IM — Improvement	What lessons from tests, incidents and audits improve our risk picture? — Active, prioritised improvement log

IDENTIFY IN PRACTICE:

Scenario: A Commonwealth agency conducts its first IDENTIFY exercise using the CSF 2.0 framework.

ID.AM: IT team runs a network discovery scan and identifies 340 assets — 62 were previously unrecorded.

ID.AM: Cloud assets across AWS and Azure are catalogued using automated CSPM tooling for the first time.

ID.AM: Shadow IT discovered — 14 SaaS applications in use without IT approval or data governance controls.

ID.RA: Risk register identifies 12 critical systems with overdue patches and 3 unsecured internet-facing APIs.

ID.RA: Business impact analysis confirms 4 systems are mission-critical, requiring priority PROTECT controls.

ID.RA: Threat intelligence review identifies 2 active threat actors targeting government agencies in the sector.

ID.IM: Pen test findings from prior quarter formally added to the improvement action log with assigned owners.

ID.IM: Vulnerability remediation SLA compliance improves from 42% to 89% after formal tracking implemented.

Outcome: IDENTIFY findings directly inform PROTECT controls and update the GOVERN risk strategy each quarter.

PR — PROTECT

Identity & Access · Training · Data Security · Platform · Resilience

PR

PROTECT

Implement safeguards to manage cybersecurity risks identified through IDENTIFY. PROTECT reduces the likelihood and impact of cybersecurity events through controls, workforce training, data protection, secure platforms and resilient infrastructure design.

FIVE PROTECT CATEGORIES — DETAILED BREAKDOWN

PR.AA — Identity Management, Auth & Access Control

- Identities managed for all users, devices and services
- Authentication strength matched to risk level of system
- Phishing-resistant MFA (FIDO2) for all privileged accounts
- Least-privilege access control applied organisation-wide
- Access reviews conducted quarterly; revoked on role change
- Physical access to sensitive areas tightly controlled
- Privileged Access Management (PAM) tool deployed for admins

PR.AT — Awareness & Training

- All personnel receive annual security awareness training
- Role-based cyber training for privileged and admin users
- Third-party provider staff trained on relevant obligations
- Phishing simulations conducted at least twice per year
- Training effectiveness measured via knowledge assessments
- Specialised incident response training for security team
- Training records maintained and reviewed by management

PR.DS — Data Security

- Data at rest encrypted — AES-256 minimum
- Data in transit encrypted — TLS 1.3 enforced
- Sensitive data identified, classified and labelled
- Data integrity mechanisms in place (hashing)
- Data loss prevention (DLP) tools deployed
- Data retention and disposal policy enforced
- Backup data encrypted and access-controlled

PR.PS — Platform Security

- Hardware and software assets maintained and hardened
- Secure configuration baselines set and monitored
- Vulnerability management programme established
- Critical patches applied within 48-hour SLA (ML3)

PR.IR — Infrastructure Resilience

- Security architectures with defence-in-depth
- Networks and environments segmented via VLANs
- Backups performed and tested — 3-2-1 strategy
- Redundancy and failover for all critical systems
- Capacity planning reviewed to prevent DoS

PROTECT — ESSENTIAL CONTROLS REFERENCE

Category	Control Domain	Minimum Requirement
PR.AA	Identity & Access	FIDO2 / phishing-resistant MFA for all privileged & remote access; least-privilege enforced org-wide
PR.AT	Awareness & Training	Annual security awareness for all staff; role-based admin training; phishing simulations twice per year
PR.DS	Data Security	AES-256 encryption at rest; TLS 1.3 in transit; data classified by sensitivity tier; DLP deployed
PR.PS	Platform Security	Hardened configuration baselines; critical patches applied within 48 hrs at ML3; EOL systems decommissioned
PR.IR	Infrastructure Resilience	3-2-1 backups tested quarterly; network segmentation enforced; RTO defined and validated annually

PROTECT IN PRACTICE:

Scenario: A defence contractor applies PROTECT controls aligned to the ISM PROTECTED classification tier.

PR.AA: FIDO2 hardware tokens deployed for all privileged users; PAM system enforces Just-In-Time admin access.

PR.AA: Quarterly access reviews conducted; 34 stale accounts revoked; 8 over-privileged accounts corrected.

PR.AT: Phishing simulation achieves 4% click-rate (down from 28%) after two rounds of targeted training.

PR.DS: AES-256 BitLocker enforced on all 600 endpoints; TLS 1.3 mandatory on all internal and external APIs.

PR.DS: Data classification tool deployed; 3,400 sensitive files identified and re-permissioned appropriately.

PR.PS: GPO enforces CIS benchmark hardening across all Windows endpoints; EOL Windows 7 hosts fully retired.

PR.PS: Vulnerability scanner identifies 847 CVEs; critical CVEs resolved within 48-hour SLA (99% compliance).

PR.IR: Offline backups to tape validated quarterly; network segmented into 12 VLANs; RTO tested at 4 hours.

Outcome: Organisation achieves CSF Tier 3 (Repeatable) for all PROTECT categories within one financial year.

DE — DETECT

Continuous Monitoring · Adverse Event Analysis · Detection Tools & KPIs

DE

DETECT

Find and analyse possible cybersecurity attacks, compromises and anomalous activity. Timely detection minimises dwell time, limits data exfiltration and reduces the overall impact and cost of a cybersecurity incident before it can escalate further.

TWO DETECT CATEGORIES — DETAILED BREAKDOWN

DE.CM — Continuous Monitoring

- Networks monitored 24/7 via SIEM and IDS/IPS tools
- All system event logs collected, normalised and retained
- Baselines established; deviations trigger automated alerts
- Vulnerability scans executed weekly on all in-scope assets
- Threat intelligence feeds integrated into monitoring platform
- User and Entity Behaviour Analytics (UEBA) deployed
- Cloud workloads monitored via Cloud Security Posture Mgmt
- DNS, email and web proxy traffic analysed continuously
- Physical monitoring (CCTV, badge access) integrated with SIEM
- Log retention configured for 7+ years for compliance requirements

DE.AE — Adverse Event Analysis

- Anomalous activity detected and triaged by SOC analysts
- Indicators of Compromise (IoCs) analysed against threat intel
- Event impact and blast radius determined promptly
- Incidents formally declared from confirmed adverse events
- Root cause traced via forensic evidence collection
- MITRE ATT&CK TTPs mapped to observed attack behaviour
- Event correlation performed across multiple log sources
- False positives reviewed to continuously tune detection rules
- All analysis documented in the incident management platform
- Escalation thresholds defined for each alert severity level

DETECTION TOOLS — TWO PER ROW

SIEM Platform

- Centralised log collection and normalisation
- Correlation rule engine with custom detections
- Real-time alerting with severity classification
- Dashboards, reporting and executive views
- Long-term log retention for compliance (7+ years)
- Threat intelligence feed integration (STIX/TAXII)
- Examples: Splunk, Microsoft Sentinel, IBM QRadar

IDS / IPS Systems

- Network traffic deep packet inspection
- Signature-based and anomaly-based detection
- Inline blocking capability to stop attacks live
- East-west lateral movement traffic coverage
- SSL/TLS inspection for encrypted traffic
- Automatic signature updates from threat feeds
- Examples: Snort, Suricata, Palo Alto IPS

EDR / XDR Solutions

- Endpoint telemetry collection and analysis
- Behavioural threat detection and hunting
- Automated threat containment and response
- Memory forensics and process analysis
- Cloud workload and identity protection
- Cross-environment correlation (XDR capability)
- Examples: CrowdStrike, Microsoft Defender XDR

Vulnerability Scanner

- Authenticated and unauthenticated asset scanning
- CVE identification, CVSS scoring and prioritisation
- Configuration and compliance assessment checks
- Remediation workflow and ticket integration
- Continuous or scheduled scanning options
- Cloud and on-premises asset coverage
- Examples: Tenable Nessus, Qualys, Rapid7

DETECT — KEY PERFORMANCE METRICS

Metric	Description & Target
Mean Time to Detect (MTTD)	Average time from incident start to detection. Target: under 24 hours for all critical events
Alert False Positive Rate	Ratio of false alerts to total alerts generated. Target: below 15% to maintain SOC analyst efficiency
Log Source Coverage	Percentage of critical assets shipping logs to SIEM. Target: 100% of Tier 1 and Tier 2 assets
Vulnerability Scan Coverage	Percentage of in-scope assets scanned weekly. Target: 100% of all internet-facing systems
Detection Rule Freshness	Age of most recent SIEM detection rule update. Target: reviewed and updated at least monthly

DETECT IN PRACTICE:

Scenario: A healthcare organisation deploys a SIEM (DE.CM) and immediately detects 3 previously unknown threats.

Discovery 1: A legacy FTP server communicating to a known C2 IP address — undetected for 47 days prior to SIEM.

Discovery 2: Unusual off-hours login from a terminated employee account that had not been disabled (PR.AA gap).

Discovery 3: Ransomware dropper detected in an email attachment via sandbox analysis in the email gateway.

DE.AE: All three events triaged by the SOC, mapped to MITRE ATT&CK TTPs and escalated to the IR team.

DE.AE: Root cause analysis for Discovery 1 reveals a misconfigured firewall rule allowing outbound FTP traffic.

MTTD improves from 14 days (pre-SIEM industry average) to under 4 hours after 90 days of tuning and rule work.

RS — RESPOND

Incident Management · Analysis · Communication · Mitigation · Improvement

RS

RESPOND

Take timely and effective action regarding a detected cybersecurity incident to contain its spread and limit the overall impact. Effective response requires pre-defined playbooks, clear roles and responsibilities, rapid communication and documented mitigation actions.

FIVE RESPOND CATEGORIES — ROW 1 OF 2

RS.MA — Incident Management

- Incident formally declared and severity level assigned
- Response plan activated and Incident Commander named
- Scope and blast radius of incident assessed promptly
- All response actions documented in the IR platform
- Escalation path followed as per the IR playbook

RS.AN — Incident Analysis

- Forensic evidence collected with chain of custody
- Root cause of the incident identified and confirmed
- MITRE ATT&CK TTPs mapped to observed attack activity
- Impact and data affected fully characterised
- Attack timeline reconstructed from log evidence
- Attribution assessed where evidence permits

RS.CO — Incident Communication

- Internal stakeholders notified per comms plan
- Executives and board briefed at key milestones
- ASD / ACSC notified per CAT 1-4 obligations
- OAIC NDB notification prepared and submitted
- Public communications approved before release
- External partners and vendors alerted if affected

FIVE RESPOND CATEGORIES — ROW 2 OF 2

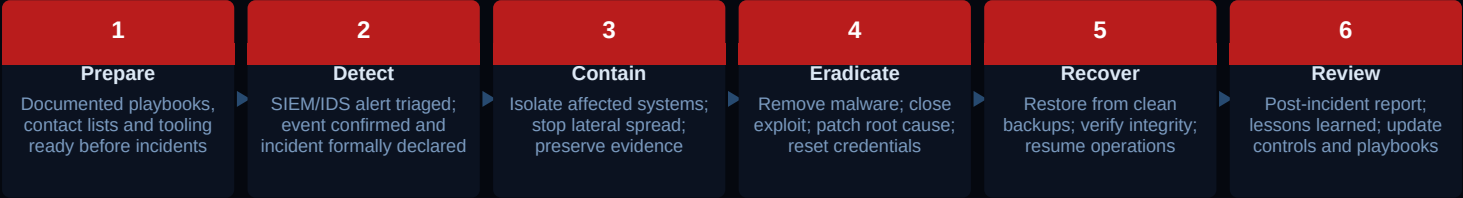
RS.MI — Incident Mitigation

- Affected systems isolated to contain lateral spread
- Malware fully eradicated from compromised systems
- Root cause exploit path patched and verified
- Compromised credentials reset and accounts locked
- Network firewall rules updated to block attack vectors
- Persistence mechanisms identified and fully removed
- Affected systems rebuilt from clean, hardened baselines
- Containment effectiveness verified before restoration

RS.IM — Response Improvements

- Post-incident review completed within 30 days
- Lessons learned formally documented and distributed
- Incident response playbooks updated with new steps
- Identified control gaps addressed with remediation plans
- Security awareness training refreshed based on incident
- Cybersecurity policies updated to prevent recurrence
- Findings and recommendations shared with GOVERN (GV.OV)
- Improvement effectiveness tracked with defined metrics

INCIDENT RESPONSE LIFECYCLE



ASD CYBER INCIDENT REPORTING OBLIGATIONS

Category	Severity	Notify By	Description
CAT 1	Critical	Within 1 hr	Compromised classified system or disruption to critical national infrastructure
CAT 2	High	Within 4 hrs	Significant data breach, ransomware on sensitive systems or major service disruption
CAT 3	Medium	Within 24 hrs	Unauthorised access confirmed — no confirmed data exfiltration at time of report
CAT 4	Low	Within 72 hrs	Policy violation or minor anomaly detected — no confirmed breach or exfiltration

RESPOND IN PRACTICE:

Scenario: 11:42 PM Friday — SIEM alert triggers; ransomware encryption activity detected on agency file servers.

RS.MA: Incident Commander declared within 6 minutes; Severity 1 activated; IR plan executed immediately.

RS.AN: SOC confirms ransomware variant is LockBit 3.0; MITRE ATT&CK T1486 (Data Encrypted for Impact) mapped.

RS.MI: Affected VLANs isolated within 8 minutes; encryption process halted before reaching classified systems.

RS.CO: ASD notified (CAT 2) within 4 hours; OAIC NDB notification prepared; CEO and board briefed at 2:00 AM.

RS.CO: Legal counsel engaged; public statement approved; all external comms funnelled through single spokesperson.

RS.IM: Post-incident review (30 days) uncovers 3 critical gaps: no email sandbox, no EDR on legacy hosts, no MFA on VPN.

RS.IM: All three gaps addressed within 60 days; playbook updated with 12 new steps; tabletop exercise scheduled.

Outcome: Organisation progresses from Tier 2 to Tier 3 for RESPOND following post-incident improvements.

RC — RECOVER

Recovery Plan Execution · Recovery Communication · Recovery Improvements

RC

RECOVER

Restore assets, operations and services affected by a cybersecurity incident to normal or improved operation in a timely, verified and coordinated manner. Recovery must be pre-planned, regularly tested and clearly communicated to all stakeholders at every stage.

THREE RECOVER CATEGORIES — DETAILED BREAKDOWN

RC.RP Incident Recovery Plan Execution

- Recovery plan formally activated post-containment
- Backup integrity validated before any restoration begins
- Systems restored in defined business priority order
- Integrity and functionality verified post-restoration
- Normal operations formally confirmed by system owner
- Clean-state image deployed where full restore required
- Recovery Time Objective (RTO) tracked against SLA
- Recovery Point Objective (RPO) validated against latest backup
- Infrastructure rebuilt from hardened baselines only
- Recovery actions documented in the IR platform

RC.CO Recovery Communication

- Internal stakeholders updated throughout restoration
- Executives and board briefed at key milestones
- Customers and users notified as services restore
- Regulators informed of recovery progress and timeline
- External partners and suppliers coordinated as needed
- Public communications approved before any releases
- Media enquiries managed by single appointed spokesperson
- Recovery ETA communicated with realistic timeframe
- Post-recovery confirmation sent confirming full restoration
- Lessons from communication process formally documented

RC.IM Recovery Improvements

- Post-incident review completed within 30 days
- Recovery plan gaps formally identified and documented
- Plan updated with all lessons learned from the incident
- Backup strategy reviewed; gaps addressed promptly
- RTO and RPO targets reassessed against actual performance
- Infrastructure rebuild time tested and optimised
- Recovery exercises run annually to validate the full plan
- Improvements fed back into GOVERN (GV.OV) for strategic planning
- Updated plan communicated to all recovery team members
- Recovery metrics tracked and reported to leadership

BACKUP STRATEGY — 3-2-1 RULE AND REQUIREMENTS

Strategy Element	Requirement	Implementation Guidance
3 Copies of Data	At minimum 3 copies total	Production data plus 2 separate backup copies maintained at all times
2 Different Media	At least 2 different storage types	e.g. local disk plus cloud object storage, or tape plus object storage
1 Offsite / Offline	At least 1 offsite or offline copy	Air-gapped offline tape or immutable cloud backup protected from ransomware
RTO Defined	Recovery Time Objective (RTO) set	Maximum acceptable time to restore operations; tested at least annually
RPO Defined	Recovery Point Objective (RPO) set	Maximum acceptable data loss window; drives backup frequency requirements
Tested Quarterly	Validate full restore capability	Full restore test performed quarterly — not just a backup health status check

RECOVER IN PRACTICE:

Scenario: Following a Friday night ransomware incident detected by SIEM, RECOVER is activated Saturday morning.

RC.RP: IT team validates 3 offline backup tapes from Thursday; integrity checksums verified before restoration.

RC.RP: Systems restored in business priority order: finance first (RTO: 4 hrs), then HR and comms (RTO: 8 hrs).

RC.RP: All restored systems rebuilt from hardened GPO baselines — not from potentially compromised backup images.

RC.RP: Each restored system validated by system owner before being returned to production use by end-users.

RC.CO: CEO provides approved public statement at 9:00 AM; OAIC NDB notification submitted by 10:00 AM Saturday.

RC.CO: All-staff email sent at 11:00 AM confirming systems are being restored; helpdesk briefed with FAQs.

RC.IM: Post-incident review finds backup RPO of 72 hours is insufficient; reduces to 24-hour backup frequency.

RC.IM: Recovery runbook gaps identified; 6 new steps added; full recovery exercise scheduled for next quarter.

Outcome: Full operations restored within 14 hours; organisation updates RECOVER Target Profile to Tier 3.

CSF Implementation Tiers

Tier 1: Partial · Tier 2: Risk Informed · Tier 3: Repeatable · Tier 4: Adaptive

Tiers describe the degree to which an organisation's cybersecurity risk management practices reflect CSF characteristics across the Risk Management Process, the Risk Management Programme, and External Participation. Tiers are NOT compliance levels.

FOUR IMPLEMENTATION TIERS

TIER 1 — PARTIAL

Informal, ad-hoc and largely reactive cybersecurity practices

1

- No formal risk management processes exist
- Ad-hoc, reactive, undocumented practices only
- No organisation-wide cyber risk awareness
- No defined incident response process in place
- Limited information sharing internally at all
- Cybersecurity confined to IT only, no business link

TIER 2 — RISK INFORMED

Risk-aware but not policy-mandated or consistently applied across the organisation

2

- Risk practices approved but not mandated as policy
- Leadership aware of cyber risk at a high level only
- Risk considered informally — not assessed org-wide
- Some cyber info shared, but not through formal processes
- Practices vary significantly between teams and divisions
- Ad-hoc external sharing — no formal agreements in place

TIER 3 — REPEATABLE

Formally approved, consistently applied and updated across the entire organisation

3

- Cyber risk practices approved as organisational policy
- Practices consistently applied and updated org-wide
- Senior leadership actively manages cyber risk daily
- Roles, responsibilities and authorities clearly defined
- Cyber information shared consistently via formal process
- Formal external information sharing agreements in place

TIER 4 — ADAPTIVE

Culture-embedded, continuously improving and proactively evolving practices

4

- Org actively adapts based on cyber lessons and intel
- Cybersecurity embedded in culture and all decisions
- Advanced threat intelligence used in near real-time
- Continuous improvement is standard — proactive not reactive
- Cyber information shared actively with external community
- Lessons systematically captured across all six functions

TIER SELECTION AND PROGRESSION GUIDANCE

Guidance Area	Key Principle
Target Tier Selection	Tiers are NOT compliance levels — select a target aligned to your risk tolerance and business goals
Progression	Movement to higher tiers is desirable but not mandatory — always based on org risk context and needs
Starting Assessment	Use a Current Profile to assess where you are today; document gaps to reach your chosen target tier
Scope of Tiers	Tiers apply organisation-wide, not to individual functions, systems or business units separately
Review Cadence	Reassess your tier at least annually or when significant risk changes or major business events occur

TIER PROGRESSION IN PRACTICE:

Scenario: A Commonwealth agency self-assesses at Tier 1 — no formal risk policy; reactive incident response only.
12-month target: achieve Tier 3 (Repeatable) across all six CSF 2.0 functions with board-level approval.
Quarter 1 — GOVERN: Risk appetite statement approved by Secretary; cybersecurity policy suite reviewed (GV.RM, GV.PO).
Quarter 2 — IDENTIFY: Asset register created with 340 assets; risk register established with 18 identified risks.
Quarter 3 — PROTECT: MFA enforced organisation-wide; hardened GPO baseline deployed to all 600 endpoints.
Quarter 4 — DETECT: SIEM deployed; 24/7 SOC monitoring established; Mean Time to Detect reduces to under 6 hours.
Quarter 4 — RESPOND/RECOVER: IR playbook published; tabletop exercise run; offline backups validated quarterly.
Outcome: Agency achieves Tier 3 at 11 months. Board briefed. ISM IRAP assessment scheduled for next financial year.

CSF Profiles & Implementation

Current Profile · Target Profile · Community Profiles · Six-Step Approach

UNDERSTANDING CSF PROFILES

Current Profile — The As-Is State

- Snapshot of cybersecurity outcomes being achieved NOW
- Mapped against all relevant CSF categories and subcategories
- Identifies existing controls, processes and capabilities in place
- Reveals gaps, inconsistencies and areas of weakness
- Created via self-assessment, audit, or gap analysis tool
- Serves as the starting baseline for all improvement work
- Updated whenever significant changes occur to the environment

Target Profile — The To-Be State

- Documents desired cybersecurity outcomes for the future state
- Aligned to organisation risk tolerance and business priorities
- Informed by GOVERN risk strategy (GV.RM) and legal obligations
- Considers regulatory requirements and applicable standards
- Gap = Target Profile minus Current Profile = priority actions
- Drives cybersecurity roadmap, investment and budget planning
- Reviewed and updated annually with senior leadership sign-off

COMMUNITY PROFILES — NEW IN CSF 2.0

What Are Community Profiles?	Who Benefits Most?	Available Examples
• Pre-built profiles for specific sectors or use cases • Created collaboratively by industry groups and NIST • Provide a shared starting baseline for a sector • Reduce duplication in profile development effort	• SMEs with limited cybersecurity resources • Organisations just beginning their CSF journey • Sectors wanting consistent baseline expectations • Regulators wanting uniform sector-wide standards • Consultants onboarding clients to CSF 2.0	• Small Business Quick Start Guide (SBQSG) • Enterprise risk management integration guide • Ransomware risk management profile (NISTIR) • Healthcare sector community profile • Water sector cybersecurity baseline profile • Financial services baseline profile

CSF 2.0 — SIX-STEP IMPLEMENTATION APPROACH

1 Scope & Prioritise Define org context, mission priorities and risk environment via GOVERN	2 Orient Identify applicable threats, risks, legal obligations and existing controls	3 Current Profile Document current cybersecurity outcomes mapped against CSF categories
4 Risk Assessment Conduct detailed risk assessment for all in-scope systems and assets	5 Target Profile Define desired future outcomes aligned to risk tolerance and strategy	6 Action Plan Build gap-closing roadmap — prioritise, resource, execute and measure

KEY IMPLEMENTATION CONSIDERATIONS

Consideration	Guidance
Start with GOVERN	Define risk appetite, roles and policy before implementing any technical controls org-wide
Use Quick Start Guides	NIST provides free QSGs tailored for SMEs, enterprises and specific industry sectors
Align to existing controls	Map ISO 27001, ISM or E8 controls already in place to CSF — avoid duplicating effort
Iterate, not one-shot	CSF is a continuous improvement framework — revisit Current and Target Profiles annually
Gain executive sponsorship	Tier progression requires leadership commitment — GOVERN must be driven from the very top

PROFILES IN PRACTICE:

Scenario: A mid-sized Australian energy company uses CSF 2.0 profiles to build its annual cybersecurity roadmap.

Current Profile: 22 CSF categories assessed — 14 partially met, 5 not met at all, 3 fully met (basic PROTECT in place).

Target Profile: 20 of 22 categories to be fully met within 18 months, aligned to SOCI Act obligations.

Gap Analysis: Priority actions identified in GV.SC (no supply chain policy), DE.CM (no SIEM), RS.MA (no IR plan).

Action Plan: 3-phase roadmap built; Phase 1 governance (Q1), Phase 2 detection and response (Q2-Q3), Phase 3 optimise (Q4).

Community Profile: Company adopts the Energy Sector Community Profile as a baseline, reducing assessment effort by 40%.

Profile Update: At 12 months, Current Profile is re-assessed; 18 of 22 categories now fully met — 2 ahead of schedule.

Outcome: Organisation achieves Tier 3 six months ahead of schedule; SOCI Act compliance assessment passed with no gaps.

Alignment, Comparison & Key Takeaways

CSF 2.0 vs ISO 27001 vs ISM · Essential Eight Mapping · Core Principles

FRAMEWORK COMPARISON — CSF 2.0 vs ISO 27001:2022 vs ASD ISM

Aspect	NIST CSF 2.0	ISO/IEC 27001:2022	ASD ISM
Primary Focus	Outcomes-based cyber framework	Information security mgmt system	Govt cyber controls and guidelines
Applicability	All orgs globally, any sector	All orgs globally, certifiable	AU Commonwealth and critical infra
Compliance Type	Voluntary framework	Certifiable via external audit	Mandatory for AU govt entities
Structure	6 Functions, 22 Categories	93 controls across 4 themes	900+ individual controls
Maturity Model	Tiers 1–4 (Partial to Adaptive)	Assessed via formal audit	ML1–ML3 per Essential Eight
Best Used For	Holistic risk programme framework	Formal ISMS certification	ASD-aligned government security

CSF 2.0 ALIGNED TO ACSC ESSENTIAL EIGHT

Essential Eight Strategy	CSF 2.0 Category	Alignment Summary
1. Patch Applications	PR.PS — Platform Security	App patching within SLAs; internet-facing systems first
2. Patch Operating Systems	PR.PS — Platform Security	OS patches within 48 hrs at ML3; EOL systems removed
3. Multi-Factor Auth	PR.AA — Identity & Access	MFA mandatory for all remote access and privileged accounts
4. Restrict Admin Privileges	PR.AA — Identity & Access	Least privilege enforced; JIT admin access via PAM
5. Application Control	PR.PS — Platform Security	Allowlisting — only approved signed executables run
6. Restrict Office Macros	PR.PS — Platform Security	Unsigned macros blocked; digitally-signed macros only
7. User Application Hardening	PR.PS — Platform Security	Browsers and Office hardened via Group Policy Object
8. Regular Backups	PR.IR — Infrastructure Resilience	Backups isolated; tested quarterly; 3-2-1 strategy

FOUR CORE PRINCIPLES TO REMEMBER

Outcomes-Based CSF describes WHAT to achieve, never HOW. It is technology-agnostic, sector-agnostic and applies to any organisation at any maturity level worldwide.	Risk-Driven Every control decision flows from GOVERN risk strategy. Classify and understand your risks before implementing any technical controls or spending any budget.
Continuous Cycle Not a one-off project. Continuously: GOVERN → IDENTIFY → PROTECT → DETECT → RESPOND → RECOVER → improve and repeat.	Universal Scope CSF 2.0 is explicitly designed for any organisation, any sector, any size — from a 5-person SME to a sovereign government or multinational enterprise.

COMPLETE QUICK REFERENCE

CSF 2.0 Overview	Voluntary outcomes framework · NIST · Feb 2024 · Universal applicability
GOVERN (GV)	6 Categories: OC, RM, RR, PO, OV, SC · NEW in 2.0 · Cross-cutting foundation
IDENTIFY (ID)	3 Categories: AM, RA, IM · Understand risk landscape · Asset and risk management
PROTECT (PR)	5 Categories: AA, AT, DS, PS, IR · Safeguards · MFA, encryption, hardening
DETECT (DE)	2 Categories: CM, AE · 24/7 monitoring and threat detection · SIEM, IDS, EDR
RESPOND (RS)	5 Categories: MA, AN, CO, MI, IM · Incident containment and eradication
RECOVER (RC)	3 Categories: RP, CO, IM · Restoration · 3-2-1 backups · RTO / RPO
Tiers	Tier 1 (Partial) → Tier 2 (Risk Informed) → Tier 3 (Repeatable) → Tier 4 (Adaptive)
Profiles	Current Profile (as-is) → Target Profile (to-be) → Gap = priority action roadmap

Thanks for Reading!

Yadav Ghorasainee

linkedin.com/in/yadav-ghorasainee
yadavgybernet.github.io/sec/

ISM · GDPR · APFS · CSF 2.0 · Essential Eight